

Security Audit Report — H1 2026

Executive Summary

The H1 2026 internal security audit covered vulnerability scanning, penetration testing, dependency auditing, and access control across all production services. The audit found the overall security posture strong, with three medium findings and no critical findings. All medium findings have remediation owners and dates.

Scope included the API gateway, auth service, billing pipeline, and the Postgres and Redis data stores. Evidence was collected from Trivy scans, Burp Suite sessions, AWS IAM policy reviews, and audit logging dashboards.

Findings

Finding 1 (Medium): Two internal services accepted TLS 1.1 connections. Remediation: enforce TLS 1.2+ at the load balancer; owner: platform team.

Finding 2 (Medium): Stale AWS IAM roles from the 2025 re-org retained S3 write access.

Remediation: quarterly IAM policy review added to the SOC 2 control calendar; owner: security.

Finding 3 (Medium): PagerDuty escalation for the WAF alert queue routed to a deprecated rotation. Remediation: oncall rotation updated; owner: SRE.

Methodology

Vulnerability scanning ran weekly with Trivy and Snyk across container images and npm dependencies. Penetration testing followed OWASP ASVS L2, focusing on authentication, session management, and multi-factor auth flows. Secrets management was validated against Vault access logs.

Recommendations

Adopt continuous dependency auditing in CI, expand the WAF ruleset to cover the new GraphQL endpoint, and rehearse the security incident runbook quarterly with the oncall rotation.

References

OWASP ASVS

SOC 2 control calendar